NTLM Elimination & SMB Signing — Legacy Authentication Hardening (Intune)

Implementation Solution Guide

Version 1.0.0 · 2026-07-29

Contents

Executive Summary — NTLM Elimination & SMB Signing (Legacy Authentication Hardening) 5

1. Solution Overview — NTLM Elimination & SMB Signing (Legacy Authentication Hardening) 6

What this solution is . . . 6

Why this matters (the threat this closes) . . . 6

The findings this resolves (~7) . . . 6

Where these settings live in Intune (Settings Catalog) . . . 7

How it works, step by step . . . 8

Benefits . . . 8

Limitations (be honest with buyers) . . . 8

The standard deployment model . . . 9

2. Requirements — NTLM Elimination & SMB Signing (Legacy Auth Hardening) 9

R1. Windows 10/11 devices enrolled in Intune . . . 9

R2. Supported Windows edition and build . . . 9

R3. Settings Catalog hardening policy (created during deployment) . . . 9

R4. NTLM audit policy (audit-first) . . . 10

R5. Access to NTLM operational event logs . . . 10

R6. Inventory of NTLM/SMB dependencies (built during audit) . . . 10

R7. SMB signing readiness on file servers / NAS (awareness) . . . 10

R8. Kerberos/DNS health for the Kerberos-first posture (recommended) . . . 11

R9. Change-control / rollback plan . . . 11

R10. Pilot user and pilot device . . . 11

Global Requirements — Intune Solutions (category-level) 11

G1. Microsoft Entra ID tenant . . . 11

G2. Microsoft Intune subscription . . . 11

G3. Administrative roles . . . 11

G4. Device enrollment in Intune . . . 12

G5. Pilot security group . . . 12

G6. Supported Windows baseline . . . 12

G7. Network access to Microsoft cloud endpoints . . . 12

3. Implementation — NTLM Elimination & SMB Signing (Legacy Auth Hardening) 12

Phase 1 — Assess (know the fleet before you touch it) . . . 13

Phase 2 — Audit NTLM first (find dependencies before refusing) . . . 13

Phase 3 — Configure the hardening policy . . . 14

Phase 4 — Pilot . . . 15

Phase 5 — Validate and expand . . . 16

5. Testing & Validation — NTLM Elimination & SMB Signing 17
Test 1 — Tenant readiness . . . 17
Test 2 — Audit phase produced a dependency list . . . 17
Test 3 — Policy applied on the device . . . 17
Test 4 — Profile assignment . . . 17
Test 5 — LM/NTLMv1 refused, Kerberos succeeds . . . 17
Test 6 — SMB signing enforced (both ends), shares still work . . . 18
Test 7 — Insecure guest logons and unauthenticated RPC closed . . . 18
Test 8 — Coverage report . . . 18
Test 9 — No baseline conflict (negative test) . . . 18
Acceptance gate . . . 18
6. Troubleshooting — NTLM Elimination & SMB Signing 18
Symptom: The hardening policy never applies to the device . . . 19
Symptom: Policy shows "Error" / "Conflict" in Device status . . . 19
Symptom: File shares stop working after enforcement . . . 19
Symptom: An app or service that used NTLM now fails to authenticate . . . 19
Symptom: Repeated NTLM fallback even though Kerberos "should" work . . . 20
Symptom: Legitimate RPC-based management breaks . . . 20
Symptom: SMB signing works to some servers, not others . . . 20
Symptom: Works for some devices, not others . . . 20
Symptom: Coverage report shows fewer devices than the group . . . 20
Escalation checklist . . . 20
7. Best Practices — NTLM Elimination & SMB Signing (Legacy Auth Hardening) 21
Audit before you enforce — always . . . 21
Move to Kerberos, don't just block NTLM . . . 21
Get SMB signing right on both ends . . . 21
Set RPC restriction conservatively . . . 22
Own only your slice — cross-reference the baselines . . . 22
Deploy pilot-first and reversibly . . . 22
Operate and monitor . . . 22
Change control . . . 22
8. Deliverables Summary — NTLM Elimination & SMB Signing 23
Documentation (this guide) . . . 23
PowerShell scripts (Microsoft Graph) — `NTLMHARD-Scripts.zip` . . . 23
Hero image . . . 24
How it's delivered . . . 24

Appendix A — PowerShell Scripts 25

Executive Summary — NTLM Elimination & SMB Signing (Legacy Authentication Hardening)

Windows endpoints still accept and emit **legacy authentication** that attackers depend on: LM/NTLMv1 responses, NTLM relay, unsigned SMB traffic, insecure guest logons, and unauthenticated RPC. Every one of these is a well-worn path for credential theft, man-in-the-middle relay, and lateral movement — and most tenants have never turned them off. This solution **eliminates NTLM (v1 first, then NTLM overall) and enforces SMB signing** on Windows 10/11 endpoints via a **Microsoft Intune Settings Catalog** policy, using the exact **Local Policies\Security Options**, **MS Security Guide**, and **SMB** settings that harden the authentication stack — deployed **audit-first**, pilot-first, and fully reversible.

A deliberately scoped, distinct capability. This is the **NTLM-elimination + SMB-signing** hardening product. It resolves roughly **seven** recurring Windows Client assessment findings — LAN Manager authentication level, NTLM SSP minimum session security (client **and** server), SMB signing (client **and** server), insecure guest logons, and unauthenticated RPC restriction — as a **focused gap product**. It **cross-references** the full CIS Windows 11 and DISA STIG baselines rather than rebuilding them, so it complements those without duplication.

The defining move is **audit before enforce**. NTLM cannot be switched off blind — a domain that still has an app, scanner, NAS, or line-of-business service relying on NTLM will break if you jump straight to "Refuse". So this package puts you through Microsoft's **Restrict NTLM: Audit** settings first to **discover** where NTLM is actually used, gives you a clear read of the breakage surface, and only then walks you into enforcement in waves. This mirrors **Microsoft's own NTLM-deprecation direction** and a **Kerberos-first** posture.

This package delivers the complete, field-tested method to stand it up in Intune — written so a single administrator can follow it end to end:

- **One policy, one purpose.** A named Windows **Settings Catalog** policy — **`NTLM-SMB Hardening - Pilot`** — carrying the LAN Manager level, NTLM SSP client/server minimum session security, SMB signing (client/server), insecure-guest-logon disable, and unauthenticated-RPC restriction, deployed pilot-first.
- **Audit-first, breakage-aware.** A companion `NTLM Audit - Pilot` policy turns on NTLM auditing so you find dependencies before you refuse them — no blind enforcement.
- **Reversible by design.** Because this is a configuration policy, removing the assignment cleanly reverts to pre-hardening behavior — no re-imaging, no enrollment change.

The package follows the standard repeatable shape — **Assess** → **Configure** → **Pilot** → **Validate** → **Expand** — with exact, click-by-click Intune steps, a requirements guide that tells you how to verify *and* fix each prerequisite, five ready-to-run PowerShell scripts (Microsoft Graph), and testing/troubleshooting guides with clear pass/fail gates.

Outcome: LM and NTLMv1 refused, NTLM usage audited then eliminated where safe, SMB signing required on both ends, insecure guest logons and unauthenticated RPC shut down — a materially smaller credential-theft and relay surface across your Windows fleet, proven on a pilot before you scale.

1. Solution Overview — NTLM Elimination & SMB Signing (Legacy Authentication Hardening)

What this solution is

This solution **hardens the Windows authentication stack** on **Windows 10/11 endpoints** managed by **Microsoft Intune**. Using a **Settings Catalog** configuration policy, it refuses the weakest NTLM responses (LM and NTLMv1), enforces strong NTLM session security where NTLM is still used, requires **SMB signing** on both client and server, disables **insecure guest logons**, and restricts **unauthenticated RPC** — the legacy-authentication settings attackers rely on for credential theft, NTLM relay, and lateral movement.

Crucially, it deploys **audit-first**. NTLM is still woven through many environments (legacy apps, NAS appliances, scanners/MFPs, line-of-business services). Switching it off blind causes outages. So this package first turns on Microsoft's **Restrict NTLM: Audit** settings to **discover where NTLM is actually used**, then walks you into enforcement in waves once the breakage surface is understood.

> ***Scope, stated plainly.*** *This solution delivers a* ***focused NTLM-elimination + SMB-signing*** *hardening policy for* ***Intune-managed Windows 10/11*** *endpoints. It resolves roughly* ***seven*** *common Windows Client assessment findings (below). It is* ***not*** *a full security baseline — it deliberately* ***cross-references*** *the CIS Windows 11 and DISA STIG solutions rather than rebuilding them. It does* ***not*** *cover domain-controller-side NTLM policy, Kerberos infrastructure design, or Credential Guard (adjacent, separate topics called out where relevant).*

Why this matters (the threat this closes)

• **LM / NTLMv1 responses** are cryptographically weak and trivially cracked or relayed. A domain that still *sends* LM/NTLMv1 hands attackers an easy credential path.

• **NTLM relay** — an attacker relays a coerced NTLM authentication to another service. **SMB signing** on both ends defeats SMB relay by making tampered/relayed sessions fail integrity checks.

• **Insecure guest logons** let a client fall back to unauthenticated SMB access to a rogue share — a known data-exfiltration and malware-delivery vector.

• **Unauthenticated RPC** widens the remote attack surface for the RPC runtime.

• **Microsoft's direction is NTLM deprecation and Kerberos-first.** Hardening now aligns the fleet with where Windows is going and shrinks the attack surface today.

The findings this resolves (~7)

This product is built to clear these recurring Windows Client assessment findings:

1. **LAN Manager authentication level** too permissive → set to *Send NTLMv2 responses only. Refuse LM & NTLM* (`LmCompatibilityLevel = 5`).

1. **NTLM SSP minimum session security — clients** weak → *Require NTLMv2 session security* + *Require

128-bit encryption* (`NtlmMinClientSec = 0x20080000`).

1. **NTLM SSP minimum session security — servers** weak → same two requirements

(`NtlmMinServerSec = 0x20080000`).

1. **SMB signing — client** not required → *Microsoft network client: Digitally sign communications

(always) = Enabled*.

1. **SMB signing — server** not required → *Microsoft network server: Digitally sign communications

(always) = Enabled* (`RequireSecuritySignature`).

1. **Insecure guest logons** allowed → *Enable insecure guest logons = Disabled*

(`AllowInsecureGuestAuth = 0`).

1. **Unauthenticated RPC clients** not restricted → *Restrict Unauthenticated RPC clients = Authenticated*

(`RestrictRemoteClients = 1`).

Plus the enabling control: **Restrict NTLM: Audit** (in-domain + outgoing) so dependencies are found before NTLM is refused.

Where these settings live in Intune (Settings Catalog)

All settings are delivered through **Devices** → **Configuration** → **Settings Catalog** (platform **Windows 10 and later**). They come from three catalog areas backed by the **LocalPoliciesSecurityOptions** and **ADMX-backed** CSP nodes:

• **Local Policies\Security Options** — LAN Manager authentication level; NTLM SSP minimum session

security (client/server); SMB "Digitally sign communications (always)" for client and server; and the **Restrict NTLM: Audit** settings.

• **Administrative Templates** → **Network** → **Lanman Workstation** — *Enable insecure guest logons* =

Disabled.

• **Administrative Templates** → **System** → **Remote Procedure Call** — *Restrict Unauthenticated RPC clients*

= **Enabled** → **Authenticated**.

> ***Verify exact catalog display strings in your tenant.*** *The Settings Catalog search box surfaces these by name (e.g. type *"LAN Manager authentication level"* or *"digitally sign communications"*). Microsoft occasionally revises the exact display text and CSP node casing; the* ***underlying registry values*** *(`LmCompatibilityLevel`, `NtlmMinClientSec`/`NtlmMinServerSec`, `RequireSecuritySignature`, `AllowInsecureGuestAuth`, `RestrictRemoteClients`) are the stable identity of each control — confirm the display string maps to the intended value before you enforce.*

How it works, step by step

1. **Assess.** Run `NTLMHARD-Discovery.ps1` to inventory the current posture across the tenant and confirm the device baseline; decide the pilot group.

1. **Audit NTLM.** Deploy the `NTLM Audit - Pilot` Settings Catalog policy (Restrict NTLM: *Audit* in-domain and outgoing). Let it run and collect the NTLM operational event logs to find every app, appliance, and service still using NTLM.

1. **Configure enforcement.** Build the `NTLM-SMB Hardening - Pilot` Settings Catalog policy with the seven settings above.

1. **Pilot.** Assign to the pilot group; validate that endpoints still reach shares, apps, and services and that SMB/NTLM behavior is correct.

1. **Validate & expand.** Confirm with `NTLMHARD-Validation.ps1` / `NTLMHARD-Report.ps1`, remediate gaps with `NTLMHARD-Remediation.ps1` (safe preview), then widen in waves.

Benefits

- **Real attack-surface reduction** — refuses LM/NTLMv1, defeats SMB relay with signing, closes guest logons and unauthenticated RPC.
- **No blind breakage** — audit-first finds NTLM dependencies before you refuse them.
- **Focused and de-duplicated** — resolves the specific legacy-auth findings without re-shipping a whole CIS/STIG baseline.
- **Reversible** — a configuration policy only; unassign to revert. No re-imaging, no enrollment change.
- **Aligned with Microsoft's roadmap** — NTLM deprecation / Kerberos-first.

Limitations (be honest with buyers)

- **Windows 10/11, Intune-managed, Pro/Enterprise/Education.** Some Local Security Options controls are not available on Home/Core editions.
- **NTLM elimination requires diligence.** If audit reveals a hard NTLM dependency you cannot yet remove (e.g. a legacy NAS), you may need to keep that service on Kerberos or replace it before refusing NTLM fleet-wide — the audit phase exists precisely to surface this.
- **Endpoint-scope only.** This hardens the **client/member** side. Domain-controller NTLM audit/block policy and Kerberos infrastructure are adjacent and out of scope.
- **Exact Settings Catalog strings can change.** Identifiers reflect current Microsoft documentation —

verify them in your tenant before fleet rollout rather than assuming.

The standard deployment model

This solution uses **one** repeatable model across our catalog:

> ***Intune-managed Windows 10/11 endpoints receive a Settings Catalog policy that audits NTLM first, then refuses LM/NTLMv1, enforces strong NTLM session security and SMB signing on both ends, and closes insecure guest logons and unauthenticated RPC — deployed pilot-first and reversible.***

Every step follows the repeatable pattern: **Assess** → **Configure** → **Pilot** → **Validate** → **Expand.**

2. Requirements — NTLM Elimination & SMB Signing (Legacy Auth Hardening)

Confirm **every** requirement below before you begin. Each entry follows the same pattern: **Description · Why required · How to verify · How to implement if missing.** Category-wide prerequisites (tenant, Intune licensing, admin roles, pilot group, network) are covered once in the **Global Requirements — Intune Solutions** document; the items here are specific to hardening NTLM and SMB on Windows 10/11 endpoints via the Settings Catalog.

> ***Scope reminder.*** *These requirements are for the* ***endpoint (client/member) side*** *legacy-auth hardening policy. They deliberately do* ***not*** *include domain-controller NTLM policy, Kerberos infrastructure, or a full CIS/STIG baseline (cross-referenced, separate solutions).*

R1. Windows 10/11 devices enrolled in Intune

Description: The target devices are Intune-enrolled Windows 10 (21H2+) or Windows 11 endpoints. **Why:** The Settings Catalog policy is delivered by Intune MDM; it only reaches enrolled devices. **Verify:** Intune admin center (`https://intune.microsoft.com`) → **Devices** → **Windows** → **Windows devices**; the device is listed and **managed / compliant**. **Implement:** Enroll via Automatic Enrollment (Entra join + MDM auto-enroll) or Autopilot so the device appears under **Devices** → **Windows**. (Enrollment itself is covered by the enrollment solutions.)

R2. Supported Windows edition and build

Description: Windows 10 21H2+ or Windows 11, **Pro / Enterprise / Education** edition, current updates. **Why:** The **Local Policies\Security Options** controls (LAN Manager level, NTLM SSP session security, SMB signing) require a business edition; Home/Core does not expose all of them. **Verify:** On the device, `winver` (build) and `Get-ItemProperty 'HKLM:\SOFTWARE\Microsoft\Windows NT\CurrentVersion' EditionID`; or Intune → device → **Hardware**. `NTLMHARD-Discovery.ps1` reports both. **Implement:** Upgrade older builds via **Update rings**; move Home/Core devices to Pro/Enterprise/ Education before applying the hardening policy.

R3. Settings Catalog hardening policy (created during deployment)

Description: A Windows **Settings Catalog** policy named `NTLM-SMB Hardening - Pilot` carrying the seven legacy-auth settings. **Why:** This policy is what applies and scopes the hardening. **Verify:** Intune → **Devices** → **Configuration**; a Settings Catalog policy named **`NTLM-SMB Hardening

- Pilot** exists and is assigned to your pilot group. NTLMHARD-Discovery.ps1` confirms the settings are

present. **Implement:** Create it during deployment (Implementation Guide, Phase 3), or scaffold/assign it with the included `NTLMHARD-Remediation.ps1` / `NTLMHARD-Set-ScopeTargeting.ps1`.

R4. NTLM audit policy (audit-first)

Description: A Windows **Settings Catalog** policy named `NTLM Audit - Pilot` enabling *Network security: Restrict NTLM: Audit NTLM authentication in this domain* and *Audit Outgoing NTLM traffic to remote servers*. **Why:** NTLM must be **audited before it is refused** so you find every dependency (apps, appliances, services) before enforcement breaks them. **Verify:** The audit policy exists and is assigned to the pilot group; NTLM operational events are appearing in the endpoints' event logs (Implementation Phase 2). **Implement:** Create it during deployment (Implementation Guide, Phase 2). Keep it in place through the pilot; you can retire it once enforcement is stable.

R5. Access to NTLM operational event logs

Description: A way to read the **Applications and Services Logs** → **Microsoft** → **Windows** → **NTLM** → **Operational** event log on pilot endpoints (locally, or centrally via an event collector / log analytics). **Why:** The audit phase writes NTLM usage events there; you need them to build the dependency list. **Verify:** On a pilot device, open **Event Viewer** → **Applications and Services Logs** → **Microsoft** → **Windows** → **NTLM** → **Operational** and confirm events appear after the audit policy applies. **Implement:** Enable the NTLM operational log (it is present by default) and, ideally, forward it to a central collector (WEF) or Microsoft Sentinel / Log Analytics for fleet-wide visibility.

R6. Inventory of NTLM/SMB dependencies (built during audit)

Description: A short list of known **NTLM- or unsigned-SMB-dependent** systems — legacy apps, NAS appliances, scanners/MFPs, backup agents, line-of-business services. **Why:** Refusing NTLM or requiring SMB signing can break a device that talks to one of these; you must know them before enforcing. **Verify:** You have a table of (system → protocol used → owner → remediation plan) derived from the audit events (R5). **Implement:** Build it during the audit phase (Implementation Phase 2). For each item, plan to move it to Kerberos / signed SMB, replace it, or scope it out — before fleet enforcement.

R7. SMB signing readiness on file servers / NAS (awareness)

Description: Awareness that requiring SMB signing on the **client** means every server/NAS the client talks to must **support** SMB signing. **Why:** Enforcing *client: digitally sign (always)* against a server that cannot sign will fail the connection. **Verify:** Confirm your Windows file servers (modern Windows Server signs by default) and any third-party NAS support SMB signing; test a share from a pilot device (Testing, Test 6). **Implement:** Enable SMB signing on file servers/NAS that support it; for appliances that cannot, plan replacement or an explicit exception before fleet rollout.

R8. Kerberos/DNS health for the Kerberos-first posture (recommended)

Description: Healthy Kerberos authentication and DNS so that refusing NTLM does not simply fail — clients fall back to **Kerberos**. **Why:** NTLM elimination assumes Kerberos works; broken SPNs/DNS make services silently fall back to NTLM (which you're now refusing), causing outages. **Verify:** On a pilot device, `klist` shows Kerberos tickets for accessed services; name resolution for those services uses FQDNs (not bare IPs, which force NTLM). **Implement:** Fix SPNs and DNS so target services authenticate over Kerberos; prefer FQDN access. (Deep Kerberos infrastructure work is adjacent/out of scope — flag it to your identity team.)

R9. Change-control / rollback plan

Description: A documented rollback: unassign the `NTLM-SMB Hardening - Pilot` policy to revert. **Why:** Legacy-auth enforcement can surface unexpected dependencies; a clean revert path is required before enforcing. **Verify:** You know how to unassign the policy (Intune → Devices → Configuration → policy → Assignments) and confirm the device reverts after a sync. **Implement:** Keep the policy (do not delete) so you can re-target quickly; document the unassign step in your change ticket.

R10. Pilot user and pilot device

Description: At least one pilot user with a licensed Entra identity and one enrolled pilot Windows 10/11 device that exercises real SMB/NTLM workloads (file shares, apps). **Why:** Every solution is validated on a pilot before fleet rollout — and legacy-auth hardening must be proven against real workloads. **Verify:** The pilot device is enrolled (R1), on a supported edition/build (R2), and reaches the file shares and apps users actually use. **Implement:** Add the pilot user/device to the **pilot security group** (Global Requirement G5) used for the policy assignment.

Global Requirements — Intune Solutions (category-level)

These requirements apply to **every** solution in the **Intune Solutions** category. They are published once at the category level so individual listings stay small. Confirm these before deploying *any* Intune solution. Each entry: **Description · Why · Verify · Implement-if-missing.**

G1. Microsoft Entra ID tenant

Description: An active Microsoft Entra ID (Azure AD) tenant. **Why:** It is the identity backbone for every cloud and Intune-managed resource. **Verify:** Sign in to `https://entra.microsoft.com` as an administrator. **Implement:** Create a Microsoft 365/Azure subscription, which provisions a tenant.

G2. Microsoft Intune subscription

Description: An Intune-bearing license plan. **Why:** Intune delivers all configuration, compliance, and security policies. **Verify:** `https://intune.microsoft.com` loads; **Tenant administration** → **Tenant status** shows active. **Implement:** Assign Microsoft 365 E3/E5, Business Premium, or standalone Intune Plan 1.

G3. Administrative roles

Description: Appropriate Entra/Intune admin roles for the operator. **Why:** Creating policies and enrollment settings requires elevated rights. **Verify:** Entra → **Roles and administrators**; confirm **Intune Administrator**. **Implement:** Assign **Intune Administrator**; reserve Global Administrator for tenant-wide changes.

G4. Device enrollment in Intune

Description: Targeted Windows devices are enrolled and manageable. **Why:** Policies only reach enrolled devices. **Verify:** Intune → **Devices** → **All devices**; the device appears and is **compliant**. **Implement:** Enable **Automatic Enrollment** and join devices to Entra ID.

G5. Pilot security group

Description: A Microsoft Entra security group for pilot/targeted users or devices. **Why:** Every solution is piloted before fleet rollout. **Verify:** Entra → **Groups**; the pilot group exists. **Implement:** Entra → **Groups** → **New group** → **Security** → add members.

G6. Supported Windows baseline

Description: Windows 10 21H2+ or Windows 11 with current updates. **Why:** Modern Intune features assume a patched, supported OS. **Verify:** `winver`, or Intune → device → **Hardware**. **Implement:** Deploy **Update rings** or upgrade to Windows 11.

G7. Network access to Microsoft cloud endpoints

Description: Outbound HTTPS to Microsoft 365, Entra, and Intune service URLs. **Why:** Enrollment, policy sync, and authentication depend on these endpoints. **Verify:** From a device, reach `https://login.microsoftonline.com` and `https://enrollment.manage.microsoft.com`. **Implement:** Allow Microsoft's published Office 365/Intune URL & IP ranges through proxy/firewall.

The standard deployment model (all solutions): Assess → Configure → Pilot → Validate → Expand.

3. Implementation — NTLM Elimination & SMB Signing (Legacy Auth Hardening)

Follow these steps **in order**. The *why* for each capability lives in the Solution Overview; the steps below are deliberately short and exact so you can **click to implement**. Throughout, the repeatable pattern applies: **Assess** → **Configure** → **Pilot** → **Validate** → **Expand.** Do everything against a **pilot group** first — and **do not skip the audit phase**.

All admin-center steps use the Microsoft Intune admin center at `https://intune.microsoft.com` unless noted.

> ***This hardens endpoints (client/member side) only.*** *It audits NTLM, then refuses LM/NTLMv1, enforces NTLM SSP session security and SMB signing on both ends, and closes insecure guest logons and unauthenticated RPC. It does not touch domain-controller NTLM policy or Kerberos infrastructure.*

Phase 1 — Assess (know the fleet before you touch it)

Step 1. Confirm enrollment, edition, and build

1. Go to **Devices** → **Windows** → **Windows devices** and confirm the pilot device is **managed**.

2. Open the device → **Hardware** and confirm Windows 10 **21H2+** or Windows 11, and a **Pro / Enterprise / Education** edition (Home/Core lacks some Local Security Options — R2).

1. Run `NTLMHARD-Discovery.ps1` from an admin workstation to inventory current posture (existing NTLM/SMB policies, edition/build) across the tenant.

Step 2. Pick the pilot group and identify likely dependencies

1. Confirm your **pilot security group** (Global Requirement G5) contains the pilot user/device (R10).

2. List systems you already suspect use NTLM or unsigned SMB — legacy apps, NAS, scanners/MFPs, backup agents (R6). You will confirm and expand this in Phase 2.

Phase 2 — Audit NTLM first (find dependencies before refusing)

> ***Do not skip this.*** *Refusing NTLM blind causes outages. The audit policy reveals every app, appliance, and service still using NTLM so you can plan around them.*

Step 3. Create the NTLM audit policy

1. Go to **Devices** → **Configuration** → **Create** → **New policy**.

2. **Platform** = **Windows 10 and later**; **Profile type** = **Settings catalog** → **Create**.

3. **Basics** → **Name:** `NTLM Audit - Pilot`. Description, e.g. *Audit-only NTLM usage discovery before enforcement.* Click **Next**.

1. On **Configuration settings** → **Add settings**, search **Local Policies Security Options** and add:

• **Network Security: Restrict NTLM: Audit NTLM Authentication In This Domain** → **Enable all** *(display strings vary — verify in your tenant; the intent is "Audit all")*.

• **Network Security: Restrict NTLM: Outgoing NTLM Traffic To Remote Servers** → **Audit all**.

1. **Next** through **Scope tags**; **Assignments** → add the **pilot group**; **Review + create** → **Create**.

Step 4. Let it run, then collect NTLM usage

1. Sync the pilot devices (Company Portal → **Sync**, or **Settings → Accounts → Access work or school → Info → Sync**).

1. Leave the audit policy in place long enough to capture real usage (a **full business cycle** —

typically 1–2 weeks — covers month-end jobs, backups, and periodic tasks).

1. On pilot devices, open **Event Viewer → Applications and Services Logs → Microsoft → Windows → NTLM →

Operational** (R5) and record every source app / target server using NTLM. Where you have central collection (WEF / Sentinel / Log Analytics), query fleet-wide instead.

1. Build the **dependency table** (system → protocol → owner → plan) from what you find (R6). For each

NTLM user: move it to Kerberos (fix SPN/DNS, use FQDN — R8), replace it, or scope it out **before** enforcing.

Phase 3 — Configure the hardening policy

Step 5. Create the Settings Catalog policy

1. Go to **Devices** → **Configuration** → **Create** → **New policy**.
2. **Platform** = **Windows 10 and later**; **Profile type** = **Settings catalog** → **Create**.
3. **Basics** → **Name:** `NTLM-SMB Hardening - Pilot`. Description, e.g. *Refuse LM/NTLMv1, require NTLM

SSP session security + SMB signing (both ends), disable insecure guest logons, restrict unauthenticated RPC.* Click **Next**.

Step 6. Add the seven legacy-auth settings

On **Configuration settings** → **Add settings**, use the search box to find each control by name. Add and set each as follows (category → setting → value). **Verify the exact display string in your tenant** — the stable identity of each control is its registry value, given in parentheses.

From "Local Policies Security Options":

1. **Network Security: LAN Manager Authentication Level** → **Send NTLMv2 responses only. Refuse LM &

NTLM** *(`LmCompatibilityLevel = 5`)*.

1. **Network Security: Minimum Session Security For NTLM SSP Based (Including Secure RPC) Clients** →

enable **Require NTLMv2 session security and Require 128-bit encryption** *(`NtlmMinClientSec = 0x20080000`)*.

1. **Network Security: Minimum Session Security For NTLM SSP Based (Including Secure RPC) Servers** →

enable **Require NTLMv2 session security and Require 128-bit encryption** *(`NtlmMinServerSec = 0x20080000`)*.

1. **Microsoft Network Client: Digitally Sign Communications (Always)** → **Enable**

(client-side `RequireSecuritySignature = 1`).

1. **Microsoft Network Server: Digitally Sign Communications (Always)** → **Enable**

(server-side `RequireSecuritySignature = 1`).

From "Administrative Templates → Network → Lanman Workstation":

1. **Enable Insecure Guest Logons** → **Disabled** *(`AllowInsecureGuestAuth = 0`)*.

From "Administrative Templates → System → Remote Procedure Call":

1. **Restrict Unauthenticated RPC Clients** → **Enabled**, RPC Runtime Unauthenticated Client Restriction

= **Authenticated** *(`RestrictRemoteClients = 1`)*.

> *These are the Microsoft-documented Local Security Options / ADMX controls for NTLM and SMB hardening. Add only these; leave everything else at default.* ***Verify current display names and CSP node casing in your tenant*** *— Microsoft occasionally revises them, but the registry values above are the anchor.*

Step 7. Scope tags, assignment, review

1. **Next** through **Scope tags** (set if you use them).
2. **Assignments:** add the **pilot group**. Click **Next**.
3. **Review + create** → **Create**.

> *Prefer automation? Use `NTLMHARD-Remediation.ps1` (Microsoft Graph) to scaffold the policy and `NTLMHARD-Set-ScopeTargeting.ps1` to set/adjust the assignment (both default to* ***-WhatIf*** *— preview first, then re-run to apply), and `NTLMHARD-Discovery.ps1` to confirm the settings are present.*

Phase 4 — Pilot

Step 8. Push and confirm the policy

1. On the pilot device, force a sync (**Settings** → **Accounts** → **Access work or school** → **Info** → **Sync**, or

Company Portal → **Sync**).

1. In Intune → **Devices** → **Configuration** → `NTLM-SMB Hardening - Pilot` → **Device status**, confirm the

pilot device shows **Succeeded**.

Step 9. Validate real workloads still work

1. From the pilot device, open the file shares, apps, and services users actually use.
2. Confirm SMB access to signing-capable servers/NAS still works (R7); confirm apps that used NTLM now

authenticate over Kerberos (R8) or were remediated in Phase 2.

1. Re-check the **NTLM Operational** log: with enforcement on, remaining NTLM attempts to weak levels are

now **refused** — confirm nothing business-critical is failing.

Step 10. Confirm the hardening is effective

1. On the pilot device confirm the settings applied (Testing, Test 3): `LmCompatibilityLevel = 5`, SMB signing required, guest logons disabled, `RestrictRemoteClients = 1`.

1. Confirm a deliberate weak-auth attempt (e.g. an unsigned SMB session or an LM/NTLMv1 client) is now **rejected**, while Kerberos/signed-SMB access succeeds.

Phase 5 — Validate and expand

Step 11. Validate with the scripts

1. Run `NTLMHARD-Discovery.ps1` (tenant readiness: the hardening policy is present with the correct settings).

1. Run `NTLMHARD-Validation.ps1` to confirm the policy is **assigned** to the intended group and the pilot device reports the policy **applied**.

1. Run `NTLMHARD-Report.ps1` to produce a coverage report (which Windows devices have the hardening policy applied).

Step 12. Remediate gaps (safe by default)

1. If devices are missing or mis-scoped, run `NTLMHARD-Remediation.ps1` — it **defaults to `-WhatIf`** and prints exactly what it would create/assign. Review, then re-run with `-WhatIf:$false` to apply.

Step 13. Expand in waves

1. Once the pilot passes (Testing gate) **and** the dependency table (R6) is cleared for the next group, broaden the `NTLM-SMB Hardening - Pilot` assignment to the next wave — or make it the standard Windows legacy-auth hardening policy for the fleet.

1. Keep the `NTLM Audit - Pilot` policy running on newly added waves first, so you catch any dependencies unique to that population before enforcing.

1. Roll out in waves, validating each wave with `NTLMHARD-Report.ps1` before widening. Retire the audit policy only when a population is fully enforced and stable.

> ***Cross-reference, don't duplicate.*** *For the full Windows hardening baseline (dozens more controls), deploy the* ***CIS Windows 11*** *and/or* ***DISA STIG Windows 10/11*** *solutions. This product deliberately owns only the NTLM-elimination + SMB-signing slice so the two do not collide — if you run a full baseline that already sets these values, align on one owning policy to avoid a Settings Catalog conflict (Troubleshooting).*

5. Testing & Validation — NTLM Elimination & SMB Signing

Validate against a **pilot device** before expanding. Each test has an explicit **pass/fail gate**. Use the included PowerShell scripts (Microsoft Graph) for tenant-side checks and the on-device steps for the enforcement behavior.

> ***What "pass" means here:*** *the pilot endpoint refuses LM/NTLMv1, requires strong NTLM SSP session security and SMB signing on both ends, disables insecure guest logons, and restricts unauthenticated RPC —* ***without*** *breaking the real workloads you cleared in the audit phase.*

Test 1 — Tenant readiness

Procedure: Run `NTLMHARD-Discovery.ps1`. **Pass:** A Settings Catalog policy named `NTLM-SMB Hardening - Pilot` exists carrying the seven legacy-auth settings; the pilot devices are on a supported edition/build. **Fail:** Missing policy, missing settings, or unsupported edition → resolve before piloting.

Test 2 — Audit phase produced a dependency list

Procedure: Confirm `NTLM Audit - Pilot` ran and you have the NTLM operational events / dependency table (R6). **Pass:** You have a concrete list of NTLM users (or a confident "none") for the pilot population, each with a plan. **Fail:** No audit data → do not enforce yet; keep the audit policy running (Implementation Phase 2).

Test 3 — Policy applied on the device

Procedure: On the pilot device, confirm the settings are in effect (registry anchors):

- `HKLM:\SYSTEM\CurrentControlSet\Control\Lsa\LmCompatibilityLevel` = **5**
- `...\Lsa\MSV1_0\NtlmMinClientSec` = **0x20080000** and `NtlmMinServerSec` = **0x20080000**
- `...\LanmanWorkstation\Parameters\RequireSecuritySignature` = **1** and `...\LanmanServer\Parameters\RequireSecuritySignature` = **1**
- `...\LanmanWorkstation\Parameters\AllowInsecureGuestAuth` = **0**
- `...\Rpc\RestrictRemoteClients` = **1**

(or Intune → policy → **Device status** = **Succeeded**). **Pass:** All anchors match and Intune shows **Succeeded**. **Fail:** Any value wrong / policy Error → check Device status and a conflicting baseline (Troubleshooting).

Test 4 — Profile assignment

Procedure: Run `NTLMHARD-Validation.ps1` (or check **Devices** → **Configuration** → `NTLM-SMB Hardening - Pilot` → **Assignments**). **Pass:** The policy is assigned to the intended **pilot group** and to no unintended broad group. **Fail:** Not assigned, or assigned to "All devices" prematurely → correct the assignment (Implement Step 7 / `NTLMHARD-Set-ScopeTargeting.ps1`).

Test 5 — LM/NTLMv1 refused, Kerberos succeeds

Procedure: From the pilot device, access a Kerberos-capable service (FQDN); then attempt a scenario that would require LM/NTLMv1. **Pass:** Kerberos access succeeds silently; LM/NTLMv1 is **refused** (the weak fallback no longer authenticates). **Fail:** Kerberos access fails → likely SPN/DNS (R8), not this policy — fix Kerberos before enforcing fleet-wide. Weak auth still succeeding → confirm `LmCompatibilityLevel = 5` applied (Test 3).

Test 6 — SMB signing enforced (both ends), shares still work

Procedure: From the pilot device, open a share on a signing-capable file server/NAS; then confirm an unsigned SMB session fails. **Pass:** Signed SMB to capable servers works; an unsigned/relayed SMB session is rejected. **Fail (share broken):** The server/NAS cannot sign (R7) → enable signing on it or plan replacement/ exception; do not remove client signing to "fix" it fleet-wide.

Test 7 — Insecure guest logons and unauthenticated RPC closed

Procedure: Attempt an SMB connection that would fall back to a **guest** logon; confirm RPC clients must authenticate. **Pass:** Insecure guest SMB access is denied (`AllowInsecureGuestAuth = 0`); unauthenticated RPC is restricted (`RestrictRemoteClients = 1`) without breaking legitimate authenticated RPC. **Fail:** Guest access still succeeds → confirm the *Enable insecure guest logons = Disabled* setting applied (Step 6.6). Legitimate RPC broken → confirm you selected **Authenticated**, not **Authenticated without exceptions** (Troubleshooting).

Test 8 — Coverage report

Procedure: Run `NTLMHARD-Report.ps1`. **Pass:** The report lists the pilot device(s) as **policy applied**; counts match the assigned group. **Fail:** Devices missing from the report → run `NTLMHARD-Remediation.ps1` (`-WhatIf` first) to fix assignment/scoping.

Test 9 — No baseline conflict (negative test)

Procedure: Confirm no *other* policy (e.g. a full CIS/STIG baseline) also sets these NTLM/SMB values on the pilot device. **Pass:** Only `NTLM-SMB Hardening - Pilot` owns these settings on the device; Device status shows no **Conflict**. **Fail:** A conflict is reported → decide the single owning policy and remove the duplicate from the other (Troubleshooting), so the two solutions do not fight.

Acceptance gate

Proceed to **Expand** only when Tests 1–8 pass on at least one pilot device, Test 9 confirms no baseline conflict, and a real pilot user confirms their file shares, apps, and services still work with LM/NTLMv1 refused and SMB signing required.

6. Troubleshooting — NTLM Elimination & SMB Signing

Work top-down: confirm the **policy is applied**, then whether a **hard NTLM/SMB dependency** (not the policy) is the real cause, then **conflicts** with another baseline. Most "it broke something" cases are a dependency the audit phase should have caught, a server/NAS that cannot sign SMB, or a Kerberos (SPN/DNS) problem forcing NTLM fallback. Each symptom below gives the **likely cause** and the **fix**.

> ***Before you start:*** *confirm you completed the* ***audit phase*** *(Restrict NTLM: Audit) and cleared the dependency table (R6). Enforcing without auditing is the single biggest cause of the failures below.*

Symptom: The hardening policy never applies to the device

Likely cause: Device not synced, not assigned, not enrolled, or unsupported edition. **Fix:**

1. Confirm the device is in the **pilot group** and `NTLM-SMB Hardening - Pilot` is **assigned**

(`NTLMHARD-Validation.ps1`).

1. Force a sync (**Settings** → **Accounts** → **Access work or school** → **Info** → **Sync**).

2. Check **Devices** → **Configuration** → `NTLM-SMB Hardening - Pilot` → **Device status** for an error.

3. Confirm the device is **Pro/Enterprise/Education** (R2) — Home/Core lacks some Local Security Options.

Symptom: Policy shows "Error" / "Conflict" in Device status

Likely cause: A second policy (often a full **CIS Windows 11** or **DISA STIG** baseline) sets the same NTLM/SMB values, or a duplicate hardening policy targets the device. **Fix:**

1. Run `NTLMHARD-Discovery.ps1` to list policies touching these settings.

2. Decide the **single owning policy** for the NTLM/SMB values and remove them from the other so only one

sets each — this product owns only the legacy-auth slice by design (Implementation Step 13).

1. Ensure only **one** policy targets the device with these settings.

Symptom: File shares stop working after enforcement

Likely cause: The target file server/NAS cannot do **SMB signing** (R7), or the client now requires signing the server won't provide. **Fix:**

1. Confirm the server/NAS **supports and has SMB signing enabled** (modern Windows Server signs by

default; third-party NAS varies).

1. Where the appliance cannot sign, plan replacement or an explicit, documented exception — **do not**

drop client-side signing fleet-wide to accommodate one legacy device.

1. Re-test the share from the pilot device (Testing, Test 6).

Symptom: An app or service that used NTLM now fails to authenticate

Likely cause: A hard NTLM dependency the audit phase surfaced (or missed), now refused by `LmCompatibilityLevel = 5` / NTLM SSP session-security requirements. **Fix:**

1. Check the **NTLM Operational** log on the device for the refused attempt (source app / target).

2. Move the service to **Kerberos** — fix its SPN and use **FQDN** access, not a bare IP (bare IP forces

NTLM) (R8).

1. If it genuinely cannot use Kerberos, replace it or scope it out of enforcement until you can — this is exactly what the audit phase (R6) exists to plan for.

Symptom: Repeated NTLM fallback even though Kerberos "should" work

Likely cause: SPN/DNS problems, or access by IP/short name, force NTLM. **Fix:**

1. On the device, `klist` — confirm a Kerberos ticket is issued for the target service.
2. Fix duplicate/missing **SPNs** and ensure **DNS** resolves the service FQDN; access by **FQDN**.
3. Re-test; NTLM fallback should stop once Kerberos succeeds.

Symptom: Legitimate RPC-based management breaks

Likely cause: *Restrict Unauthenticated RPC clients* was set too strictly. **Fix:**

1. Confirm you selected **Authenticated** (`RestrictRemoteClients = 1`), **not** *Authenticated without exceptions* (`= 2`), which is more aggressive and can break management traffic.

1. Re-check the setting value in the policy (Implementation Step 6.7) and re-sync.

Symptom: SMB signing works to some servers, not others

Likely cause: Mixed server capability — some sign, some don't. **Fix:**

1. Inventory which servers/NAS support signing (R7); enable it where supported.
2. For non-signing legacy appliances, plan replacement or a documented exception; track them in the dependency table (R6).

Symptom: Works for some devices, not others

Likely cause: Group membership, edition, or a device-specific conflicting policy. **Fix:**

1. Confirm affected devices are in the assigned group (`NTLMHARD-Report.ps1`).
2. Confirm each is **Pro/Enterprise/Education** on a supported build (R2).
3. Check for a device-scoped conflicting baseline (first symptom above).

Symptom: Coverage report shows fewer devices than the group

Likely cause: Some devices not synced, not enrolled, or on an unsupported edition. **Fix:**

1. Run `NTLMHARD-Report.ps1` to list which devices lack the applied policy.
2. Run `NTLMHARD-Remediation.ps1` **(`-WhatIf` first)** to correct assignment/scoping.
3. Re-sync stragglers and confirm enrollment (R1) and edition (R2).

Escalation checklist

Before opening a Microsoft support case, collect: the `NTLMHARD-Discovery.ps1` output, the policy's Device status export, the exact settings and their applied registry values (Test 3), the NTLM Operational log excerpts for the failing flow, the target server/NAS SMB-signing capability, `klist` output, Windows edition/build, and whether the failure reproduces with the hardening policy **unassigned** (isolates this policy from an unrelated Kerberos/DNS problem).

7. Best Practices — NTLM Elimination & SMB Signing (Legacy Auth Hardening)

These practices keep NTLM elimination and SMB-signing enforcement precise, safe, and reversible on Intune-managed Windows 10/11 endpoints. They assume the deployment model in the Solution Overview: a Settings Catalog policy that **audits NTLM first**, then refuses LM/NTLMv1, enforces NTLM SSP session security and SMB signing on both ends, and closes insecure guest logons and unauthenticated RPC — deployed pilot-first.

Audit before you enforce — always

- **Never refuse NTLM blind.** Deploy `NTLM Audit - Pilot` (Restrict NTLM: Audit in-domain + outgoing) and let it run a **full business cycle** (1–2 weeks) so month-end jobs, backups, and periodic tasks show up.
- **Turn the audit into a plan.** Build the dependency table (system → protocol → owner → remediation) from the NTLM Operational log. Each NTLM user gets a decision — Kerberos, replace, or scope out — **before** enforcement reaches its population.
- **Keep auditing ahead of the wave.** Run the audit policy on each new wave first; only enforce once that population's dependencies are cleared.

Move to Kerberos, don't just block NTLM

- **Fix the cause, not the symptom.** Refusing NTLM only helps if Kerberos works — fix SPNs and DNS so services authenticate over Kerberos (R8), and access services by **FQDN** (bare IP forces NTLM).
- **Kerberos-first aligns with Microsoft's roadmap.** NTLM is being deprecated; every dependency you move to Kerberos now is one you won't scramble to fix later.

Get SMB signing right on both ends

- **Client and server both.** Enable *Digitally sign communications (always)* for **both** the Microsoft network **client** and **server** — signing on both ends is what defeats SMB relay.
- **Confirm server/NAS capability first.** Modern Windows Server signs by default; third-party NAS varies. Verify capability (R7) before enforcing client-side signing, or shares will fail.

• **Legacy appliances that can't sign** get a replacement plan or a documented exception — never a fleet-wide rollback of signing.

Set RPC restriction conservatively

• **Use "Authenticated", not "Authenticated without exceptions".** `RestrictRemoteClients = 1` (Authenticated) closes the common exposure without breaking legitimate management RPC; the stricter = 2 can break tooling — reserve it for a deliberate, tested decision.

Own only your slice — cross-reference the baselines

• **Don't rebuild CIS/STIG.** This product owns the NTLM-elimination + SMB-signing controls. For the full Windows hardening baseline, deploy the **CIS Windows 11** and/or **DISA STIG** solutions.

• **One owning policy per setting.** If a full baseline already sets these NTLM/SMB values, decide the single owning policy and remove the duplicate from the other so the Settings Catalog does not report a **Conflict**.

Deploy pilot-first and reversibly

• **Assign to a pilot group, never "All devices" first.** Expand in waves after each gate passes and each population's dependencies are cleared.

• **Rollback is unassignment.** Because this only adds a configuration policy, removing the assignment cleanly reverts to pre-hardening behavior — no re-imaging or account cleanup. Keep the policy so you can re-target quickly (R9).

Operate and monitor

• **Report before you widen.** Run `NTLMHARD-Report.ps1` each wave; only broaden when coverage matches the assigned group.

• **Remediate with `-WhatIf` first.** `NTLMHARD-Remediation.ps1` and `NTLMHARD-Set-ScopeTargeting.ps1` preview by default — read the plan, then apply.

• **Watch the NTLM Operational log after enforcing.** A spike in refused NTLM to a specific target is a missed dependency — remediate it, don't relax the policy.

Change control

• **Version scope changes.** When you adjust a setting or widen the assignment, note the date and reason; re-run Discovery and Report to confirm no regressions.

• **Review after major Windows upgrades.** Confirm the settings still apply and no new NTLM fallback appears after significant Windows feature updates before expanding further.

8. Deliverables Summary — NTLM Elimination & SMB Signing

Everything included in this solution package, and what each piece is for.

Documentation (this guide)

• **Executive Summary** — the business case and outcome in one page, and the explicit scope: a focused NTLM-elimination + SMB-signing hardening policy for Windows 10/11 endpoints, audit-first, that resolves ~7 legacy-auth findings and cross-references (not rebuilds) CIS/STIG.

• **Solution Overview** — the threat this closes (LM/NTLMv1, NTLM relay, unsigned SMB, guest logons, unauthenticated RPC), the exact settings and their registry anchors, where they live in the Settings Catalog, and the audit-first / Kerberos-first posture aligned with Microsoft's NTLM deprecation.

• **Requirements Guide** — every Intune/Windows/identity prerequisite with how to **verify** and how to **implement if missing**, plus the category-level Global Requirements.

• **Implementation Guide** — exact, ordered, click-by-click steps across five phases: assess, **audit NTLM first**, build the `NTLM-SMB Hardening - Pilot` Settings Catalog policy (seven settings), pilot, then validate and expand.

• **Testing & Validation** — nine tests with explicit pass/fail gates (including registry-anchor checks and a negative baseline-conflict test) and an acceptance gate.

• **Troubleshooting** — top-down diagnosis for policy-not-applying, broken shares, NTLM-dependent apps, Kerberos fallback, RPC breakage, and baseline conflicts.

• **Best Practices** — audit-before-enforce, move-to-Kerberos, SMB signing on both ends, conservative RPC restriction, owning only your slice vs CIS/STIG, and reversible pilot-first rollout.

PowerShell scripts (Microsoft Graph) — `NTLMHARD-Scripts.zip`

All scripts are tenant-side (run from an admin workstation with the Microsoft Graph PowerShell SDK); each has a header explaining **Purpose · How to run · Expected results**. Discovery, Validation, and Report are **read-only**; Remediation and Set-ScopeTargeting **default to** `-WhatIf` (preview first, then apply).

1. `NTLMHARD-Discovery.ps1` — tenant readiness: a Settings Catalog policy carrying the NTLM/SMB legacy-auth settings is present with the correct values, and reports the current NTLM/SMB posture.

1. `NTLMHARD-Validation.ps1` — validates the policy's **assignment** and per-device **applied** state, with a clear PASS/FAIL summary.

1. `NTLMHARD-Report.ps1` — tenant-wide CSV report of Windows devices and whether the NTLM/SMB

hardening policy is applied — the coverage report.

1. `NTLMHARD-Remediation.ps1` — safe remediation: scaffolds the Settings Catalog hardening policy if

missing (with the seven settings) and assigns it to a target group. `-WhatIf` **by default**; applies only when re-run to commit.

1. `NTLMHARD-Set-ScopeTargeting.ps1` — sets/adjusts the policy's group assignment (target-group

builder), with optional exclusion group. `-WhatIf` **by default.**

Hero image

- `NTLMHARD-hero.png` — the product image used on the marketplace listing.

How it's delivered

A **Word** document and **PDF** (cover, table of contents, page numbers, and a scripts appendix), plus all five PowerShell scripts in a single **ZIP** — yours to keep and reuse across **unlimited devices**.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

NTLMHARD-Discovery.ps1

Purpose: Confirms the Intune tenant is ready to enforce legacy-authentication hardening on Windows 10/11 endpoints: a Windows Settings Catalog policy exists carrying the NTLM/SMB controls (LAN Manager authentication level, NTLM SSP minimum session security for clients and servers, SMB signing for client and server, insecure guest logons, and unauthenticated-RPC restriction), and reports whether an audit-first NTLM policy (Restrict NTLM: Audit) is present. Read-only. This checks the endpoint (client/member) legacy-auth hardening only — not domain-controller NTLM policy or a full CIS/STIG baseline. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\NTLMHARD-Discovery.ps1 (Install once: Install-Module Microsoft.Graph -Scope CurrentUser) Required Graph scopes: DeviceManagementConfiguration.Read.All EXPECTED RESULTS A PASS/FAIL line per check and an overall verdict. A READY tenant shows a Windows Settings Catalog policy carrying the NTLM/SMB legacy-auth settings, and (recommended) a separate NTLM audit policy. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. > [CmdletBinding()] param([string]$ProfileName = 'NTLM-SMB Hardening - Pilot', [string]$AuditProfileName = 'NTLM Audit - Pilot')

How to run: powershell -ExecutionPolicy Bypass -File .\NTLMHARD-Discovery.ps1 (Install once: Install-Module Microsoft.Graph -Scope CurrentUser) Required Graph scopes: DeviceManagementConfiguration.Read.All EXPECTED RESULTS A PASS/FAIL line per check and an overall verdict. A READY tenant shows a Windows Settings Catalog policy carrying the NTLM/SMB legacy-auth settings, and (recommended) a separate NTLM audit policy. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. > [CmdletBinding()] param([string]$ProfileName = 'NTLM-SMB Hardening - Pilot', [string]$AuditProfileName = 'NTLM Audit - Pilot')

NTLMHARD-Remediation.ps1

Purpose: Remediates the common gap that leaves Windows endpoints exposed to legacy authentication: creates a Windows Settings Catalog policy carrying the core NTLM/SMB legacy-auth controls if none exists, and assigns it to a target group. Defaults to -WhatIf, so it previews every change and modifies nothing until re-run to apply. Remediates the endpoint hardening policy only — never domain-controller NTLM policy or a full CIS/STIG baseline.

How to run: Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\NTLMHARD-Remediation.ps1 -GroupId your-entra-group-object-id Apply the change: powershell -ExecutionPolicy Bypass -File .\NTLMHARD-Remediation.ps1 -GroupId your-entra-group-object-id -WhatIf:$false (Install once: Install-Module Microsoft.Graph -Scope CurrentUser) Required Graph scopes: DeviceManagementConfiguration.ReadWrite.All EXPECTED RESULTS In preview: a report of what is missing, the policy it WOULD create, and the full seven-setting plan (with registry anchors) to complete in the portal. When applied: a Windows Settings Catalog policy exists (core NTLM/SMB controls) and is assigned to the group; finish the remaining settings in the portal, then re-run NTLMHARD-Discovery.ps1. .NOTES White-label — the repeatable way. Defaults to -WhatIf; changes require -WhatIf:$false. > [CmdletBinding(SupportsShouldProcess)] param([Parameter(Mandatory)] [string]$GroupId, [string]$Name = 'NTLM-SMB Hardening - Pilot')

NTLMHARD-Report.ps1

Purpose: Produces a coverage report across Windows 10/11 devices: for each managed device, whether the NTLM/SMB legacy-auth hardening Settings Catalog policy is applied. Use it to measure coverage before widening a rollout and to find endpoints still missing the hardening. Read-only. Reports the endpoint hardening policy only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\NTLMHARD-Report.ps1 Optional: -ProfileName "NTLM-SMB Hardening - Pilot" -CsvPath .\NTLMHARD-coverage.csv (Install once: Install-Module Microsoft.Graph -Scope CurrentUser) Required Graph scopes: DeviceManagementConfiguration.Read.All, DeviceManagementManagedDevices.Read.All EXPECTED RESULTS A table (and optional CSV) of Windows devices with an Applied column (Yes/No/Error/Conflict) plus a coverage summary. Full coverage = every intended device shows Applied = Yes. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. > [CmdletBinding()] param([string]$ProfileName = 'NTLM-SMB Hardening - Pilot', [string]$CsvPath)

How to run: powershell -ExecutionPolicy Bypass -File .\NTLMHARD-Report.ps1 Optional: -ProfileName "NTLM-SMB Hardening - Pilot" -CsvPath .\NTLMHARD-coverage.csv (Install once: Install-Module Microsoft.Graph -Scope CurrentUser) Required Graph scopes: DeviceManagementConfiguration.Read.All, DeviceManagementManagedDevices.Read.All EXPECTED RESULTS A table (and optional CSV) of Windows devices with an Applied column (Yes/No/Error/Conflict) plus a coverage summary. Full coverage = every intended device shows Applied = Yes. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. > [CmdletBinding()] param([string]$ProfileName = 'NTLM-SMB Hardening - Pilot', [string]$CsvPath)

NTLMHARD-Set-ScopeTargeting.ps1

Purpose: Sets or adjusts which Entra security group the NTLM/SMB legacy-auth hardening Settings Catalog policy is assigned to — the target-group builder for pilot-first, wave-based rollout on Windows 10/11 endpoints. Optionally adds an assignment exclusion group. Defaults to -WhatIf, previewing the assignment change and modifying nothing until re-run to apply. Targets the endpoint hardening policy only, not domain-controller NTLM policy or a full CIS/STIG baseline. HOW TO RUN Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\NTLMHARD-Set-ScopeTargeting.ps1 -GroupId your-entra-group-object-id Apply the assignment: powershell -ExecutionPolicy Bypass -File .\NTLMHARD-Set-ScopeTargeting.ps1 -GroupId your-entra-group-object-id -WhatIf:$false Optional: -ExcludeGroupId your-exclusion-group-object-id ; -ProfileName "NTLM-SMB Hardening - Pilot" (Install once: Install-Module Microsoft.Graph -Scope CurrentUser) Required Graph scopes: DeviceManagementConfiguration.ReadWrite.All EXPECTED RESULTS In preview: the policy found and the assignment that WOULD be set. When applied: the policy is assigned to the include group (and excludes the exclusion group). Confirm in Intune - Devices - Configuration, or with NTLMHARD-Validation.ps1. .NOTES White-label — the repeatable way. Defaults to -WhatIf; changes require -WhatIf:$false. > [CmdletBinding(SupportsShouldProcess)] param([Parameter(Mandatory)] [string]$GroupId, [string]$ExcludeGroupId, [string]$ProfileName = 'NTLM-SMB Hardening - Pilot')

How to run: Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\NTLMHARD-Set-ScopeTargeting.ps1 -GroupId your-entra-group-object-id Apply the assignment: powershell -ExecutionPolicy Bypass -File .\NTLMHARD-Set-ScopeTargeting.ps1 -GroupId your-entra-group-object-id -WhatIf:$false Optional: -ExcludeGroupId your-exclusion-group-object-id ; -ProfileName "NTLM-SMB Hardening - Pilot" (Install once: Install-Module Microsoft.Graph -Scope CurrentUser) Required Graph scopes: DeviceManagementConfiguration.ReadWrite.All EXPECTED RESULTS In preview: the policy found and the assignment that WOULD be set. When applied: the policy is assigned to the include group (and excludes the exclusion group). Confirm in Intune - Devices - Configuration, or with NTLMHARD-Validation.ps1. .NOTES White-label — the repeatable way. Defaults to

-WhatIf; changes require -WhatIf:$false. > [CmdletBinding(SupportsShouldProcess)] param([Parameter(Mandatory)] [string]$GroupId, [string]$ExcludeGroupId, [string]$ProfileName = 'NTLM-SMB Hardening - Pilot')

NTLMHARD-Validation.ps1

Purpose: Validates the Windows NTLM/SMB legacy-auth hardening Settings Catalog policy is assigned to the intended group and applied on target devices. Confirms the policy exists, that it is assigned, and reports each Windows device's applied state (Succeeded / Error / Conflict / Not applied). Read-only. Validates the endpoint hardening policy only, not domain-controller NTLM policy or a full CIS/STIG baseline. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\NTLMHARD-Validation.ps1 -ProfileName "NTLM-SMB Hardening - Pilot" Optional: -GroupId your-entra-group-object-id (assert the policy is assigned to this group) (Install once: Install-Module Microsoft.Graph -Scope CurrentUser) Required Graph scopes: DeviceManagementConfiguration.Read.All EXPECTED RESULTS A PASS/FAIL summary: policy found, assigned (to -GroupId if supplied), and a per-device applied-state table. PASS when the policy is assigned and pilot devices report Succeeded with no Conflict. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. > [CmdletBinding()] param([string]$ProfileName = 'NTLM-SMB Hardening - Pilot', [string]$GroupId)

How to run: powershell -ExecutionPolicy Bypass -File .\NTLMHARD-Validation.ps1 -ProfileName "NTLM-SMB Hardening - Pilot" Optional: -GroupId your-entra-group-object-id (assert the policy is assigned to this group) (Install once: Install-Module Microsoft.Graph -Scope CurrentUser) Required Graph scopes: DeviceManagementConfiguration.Read.All EXPECTED RESULTS A PASS/FAIL summary: policy found, assigned (to -GroupId if supplied), and a per-device applied-state table. PASS when the policy is assigned and pilot devices report Succeeded with no Conflict. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. > [CmdletBinding()] param([string]$ProfileName = 'NTLM-SMB Hardening - Pilot', [string]$GroupId)